



МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ
РОССИЙСКОЙ ФЕДЕРАЦИИ

Федеральное государственное бюджетное
образовательное учреждение высшего образования
«Новосибирский государственный
архитектурно-строительный
университет (Сибстрин)»

Институт цифровых и инженерных технологий
Кафедра информационных систем и технологий

Заведующий кафедрой

К защите:

Информационных систем и технологий
(наименование кафедры)

(подпись)

«__» июня 2026 г.

канд. техн. наук, доцент

НГАСУ (Сибстрин) Павлов И.И.

(ученая степень, звание, должность, фамилия и инициалы)

**ВЫПУСКНАЯ
КВАЛИФИКАЦИОННАЯ РАБОТА БАКАЛАВРА**

по направлению подготовки
09.03.02 «Информационные системы и технологии»

**Тема: Проектирование и реализация защищённой системы резервного копирования
корпоративной серверной инфраструктуры с защитой от ransomware-атак**

ПОЯСНИТЕЛЬНАЯ ЗАПИСКА
ВКРБ.ИСТ.000

Семенов Андрей Алексеевич

Выполнил:

Руководитель:

Семенов А.А.

(подпись)

(фамилия и инициалы)

канд. техн. наук, доцент, Павлов И.И.

(подпись) (ученая степень, звание, должность, фамилия и инициалы)

(дата)

(дата)

Новосибирск 2026

НОВОСИБИРСКИЙ ГОСУДАРСТВЕННЫЙ
АРХИТЕКТУРНО–СТРОИТЕЛЬНЫЙ УНИВЕРСИТЕТ (СИБСТРИН)

Федеральное государственное бюджетное
образовательное учреждение высшего образования
«Новосибирский государственный
архитектурно-строительный университет (Сибстрин)»

Кафедра информационных систем и технологий

«Утверждаю»

Завкафедрой ИСТ

_____ канд. техн. наук, доцент Задорожный А.Ф.

ЗАДАНИЕ

" ____ " _____ 2026 г.

на дипломную

работу

Студенту Семенов А.А. группы 410б

Тема работы: Проектирование и реализация защищённой системы резервного копирования корпоративной серверной инфраструктуры с защитой от ransomware-атак (приказом по университету)

Срок сдачи студентом проекта (работы)

Исходные данные для проекта (работы) Язык программирования Python 3.11. Технология ядра Linux eBPF для низкоуровневого перехвата системных вызовов. Фреймворк FastAPI и Nuxt 4 (Vue 3.5, TypeScript). Система управления базами данных PostgreSQL с расширением TimescaleDB и встраиваемая СУБД SQLite. Инструменты контейнеризации Docker и Docker Compose. Программное обеспечение для резервного копирования BorgBackup (режим WORM/Append-Only). Защищенные сетевые туннели WireGuard VPN. Операционные системы семейства Linux (Ubuntu Server).

Содержание пояснительной записки к дипломной работе

1. Аннотация
2. Оглавление
3. Перечень терминов и определений
4. Перечень сокращений и обозначений
5. Введение
6. Исследование методов защиты корпоративной инфраструктуры и анализ угроз ransomware

7. Архитектурное проектирование и программная реализация защищённой системы резервного копирования
8. Экспериментальное исследование и оценка эффективности восстановления (RPO/RTO)
9. Заключение
10. Список использованных источников
11. Приложения

Перечень иллюстративного материала: Структурная схема защищённого двухсерверного backup-контура (архитектура Zero Trust), блок-схема превентивного алгоритма блокировки резервного копирования на основе анализа энтропии данных (защита от ransomware), диаграмма последовательности процесса изолированного сохранения бэкапов в режиме Append-Only (WORM), ER-диаграмма базы данных аудита файловых операций, скриншоты панели мониторинга состояния хранилища и метрик восстановления (RPO/RTO).

Дата выдачи задания: 00.00.2026 г.

Руководитель ВКР _____ к.т.н., доцент НГАСУ Павлов И.И.

(подпись, дата) (ученая степень, звание, должность, фамилия, инициалы)

Задание принял к исполнению _____ Семенов А.А.

(подпись, дата) (фамилия, инициалы)

АННОТАЦИЯ

выпускной квалификационной работы

студента группы № 4106 ФГБОУ ВО НГАСУ (Сибстрин)

Семенова Андрея Алексеевича

на тему: **«Проектирование и реализация защищённой системы резервного копирования корпоративной серверной инфраструктуры с защитой от ransomware-атак»**

Целью выпускной квалификационной работы является проектирование и разработка распределенного программного комплекса для превентивного обнаружения аномальной активности файловых систем, а также изолированного, отказоустойчивого хранения и верификации резервных копий в условиях воздействия ransomware-атак.

Работа выполнена с использованием языков программирования Go (Golang) и Python. Система управления базами данных построена на PostgreSQL с расширением TimescaleDB и локальной СУБД SQLite для ведения аудита. Клиентская часть реализована на Nuxt 4 (Vue 3.5, TypeScript).

Разработанная система реализует следующие функциональные возможности: непрерывный поведенческий аудит файловых операций с использованием технологии eBPF, превентивный алгоритм блокировки backup-контура при аномальном росте энтропии записываемых блоков данных. Внедрен механизм неизменяемого хранения Append-Only (WORM), исключающий удаление резервных копий скомпрометированной учетной записью.

Архитектура системы спроектирована по принципам Clean Architecture и разделена на независимые слои (Domain-логика, Application, Storage), что обеспечивает строгую сетевую изоляцию доменов безопасности и гарантирует невозможность латерального перемещения атакующего из продуктивной сети.

_____ Подпись студента

_____ ФИО Студента

ОГЛАВЛЕНИЕ

ВВЕДЕНИЕ.....	10
1 Исследование методов и средств защиты систем резервного копирования от вредоносного программного обеспечения.....	14
1.1 Анализ предметной области и существующих решений.....	14
1.2 Анализ векторов ransomware-атак и техник ингибирования процессов аварийного восстановления.....	15
1.3 Обоснование выбора программно-технологического стека.....	16
1.4 Постановка задачи на разработку системы.....	18

ПЕРЕЧЕНЬ ТЕРМИНОВ И ОПРЕДЕЛЕНИЙ

В настоящей работе применяют следующие термины с соответствующими определениями:

Append-Only (WORM-режим) — режим функционирования репозитория хранения, при котором поддерживается исключительно последовательная дозапись новых блоков данных, а любые операции модификации или удаления ранее созданных объектов программно или аппаратно блокируются со стороны принимающего узла.

Clean Architecture (Чистая архитектура) — подход к проектированию программного обеспечения, предполагающий разделение системы на независимые концентрические слои с четко разграниченной ответственностью, где направление зависимостей идет строго от внешних интерфейсов к центральной доменной логике.

eBPF (Extended Berkeley Packet Filter) — низкоуровневая подсистема ядра операционной системы Linux, позволяющая безопасно исполнять изолированные программы-обработчики в контексте ядра для мониторинга системных вызовов в режиме реального времени без изменения исходного кода ядра.

Ransomware (Программа-вымогатель) — специализированное вредоносное программное обеспечение, реализующее скрытное криптографическое преобразование (шифрование) пользовательских и системных файлов с целью нарушения доступности ИТ-сервисов и последующего вымогательства финансовых средств.

Инкрементное резервное копирование — метод создания копий данных, при котором переносу и сохранению подлежат только те блоки

информации или файлы, которые подверглись изменению с момента проведения предыдущей сессии резервного копирования.

Модуль превентивного анализа — программный хостовый компонент защищаемой системы, осуществляющий непрерывный поведенческий аудит файловых операций и блокирующий сессию резервного копирования до момента отправки данных в репозиторий при обнаружении признаков компрометации.

Энтропия Шеннона (применительно к файловым массивам) — математическая мера случайности или хаотичности распределения байт в анализируемом блоке данных, используемая в качестве ключевого индикатора для автоматического выявления процессов шифрования.

ПЕРЕЧЕНЬ СОКРАЩЕНИЙ И ОБОЗНАЧЕНИЙ

БД — база данных

ВКР — выпускная квалификационная работа

ВМ — виртуальная машина

ИБ — информационная безопасность

ИТ — информационные технологии

ОС — операционная система

СУБД — система управления базами данных

API (Application Programming Interface) — программный интерфейс приложения

IOPS (Input/Output Operations Per Second) — количество операций ввода-вывода в секунду (метрика производительности дисковой подсистемы)

RPO (Recovery Point Objective) — целевая точка восстановления (максимально допустимый период возможной потери данных в результате сбоя)

RTO (Recovery Time Objective) — целевое время восстановления (максимально допустимое время простоя системы до полного восстановления работоспособности)

VFS (Virtual File System) — виртуальная файловая система операционной системы

VPN (Virtual Private Network) — виртуальная частная сеть

WORM (Write Once, Read Many) — однократная запись, многократное чтение (концепция неизменяемого хранения данных)

ВВЕДЕНИЕ

Актуальность темы. В условиях масштабной цифровизации и перевода критически важных бизнес-процессов современных организаций в распределенные информационные среды обеспечение непрерывности функционирования ИТ-инфраструктуры становится приоритетной задачей информационной безопасности. Одним из наиболее разрушительных векторов кибератак на сегодняшний день является использование вредоносного программного обеспечения класса ransomware (программ-вымогателей). Эволюция данного типа угроз привела к переходу от массовых веерных заражений к сложным целевым атакам (Human-Operated Ransomware), направленным непосредственно на компрометацию корпоративной серверной инфраструктуры.

Согласно аналитическим данным команды реагирования на инциденты (GERT) «Лаборатории Касперского», в их практике доля инцидентов, связанных с ransomware, выросла с 33,3% в 2023 году до 41,6% в 2024 году, что указывает на устойчивый характер данной угрозы для корпоративного сектора. Эксперты компании BI.ZONE также подчеркивают, что критическими факторами риска для организаций остаются отсутствие регулярного резервного копирования, бесконтрольное предоставление прав администратора и компрометация инфраструктуры через незащищенных подрядчиков. При этом доля высококритичных инцидентов, реализованных через атаки на цепочку поставок (подрядчиков), к началу 2025 года достигла 30%.

Основная техническая проблема заключается в том, что традиционное понимание «наличия бэкапа» более не является гарантией успешного восстановления работоспособности сервисов. В сценариях современных целевых атак злоумышленники стремятся не просто зашифровать продуктивные данные, но и полностью подавить механизмы аварийного восстановления: уничтожить снимки файловых систем, очистить каталоги резервных копий и скомпрометировать управляющие серверы. Данный вектор деструктивного воздействия формализован в международной таксономии кибератак MITRE ATT&CK как техника «Inhibit System Recovery» (T1490).

Если система резервного копирования (СРК) развернута в рамках общего домена аутентификации или доступна напрямую из продуктивной

сети (Flat Network), компрометация учетных данных администратора ведет к одновременной потере как продуктивного сегмента, так и архивных данных. Это обуславливает острую необходимость проектирования и реализации изолированных киберустойчивых backup-контуров, обладающих автономными границами доверия, механизмами неизменяемого хранения данных (WORM/Append-Only) и встроенными программными средствами превентивного поведенческого анализа файловой активности.

Методической основой исследования служат российские нормативно-методические источники, включая Методику оценки угроз безопасности информации ФСТЭК России от 05.02.2021 года и Банк данных угроз ФСТЭК. Вопросы обеспечения непрерывности бизнес-процессов и готовности ИКТ-инфраструктуры регламентируются положениями национальных стандартов ГОСТ Р ИСО 22301 и ГОСТ Р ИСО/МЭК 27031.

Цель работы — разработать архитектуру и методику экспериментальной проверки защищенной системы резервного копирования корпоративной серверной инфраструктуры, устойчивой к ransomware-атакам и попыткам уничтожения резервных копий, с измерением целевых параметров восстановления (RPO/RTO).

Для достижения поставленной цели необходимо решить следующие задачи:

- провести комплексный анализ актуальных векторов ransomware-атак на компоненты хранения данных и обосновать модель угроз backup-контура по методике ФСТЭК России;
- спроектировать распределенную архитектуру защищенного backup-контура, функционирующую на принципах сетевой изоляции и разделения доменов администрирования;
- разработать модуль превентивного анализа файловой активности с использованием технологии eBPF для выявления аномалий ввода-вывода на продуктивном сервере;

- реализовать математический алгоритм оценки энтропии блоков данных для предотвращения резервного копирования зашифрованных массивов информации;
- настроить подсистему хранения данных в режиме Append-Only (WORM-хранение) с реализацией политик автоматического удержания (Retention) ;
- развернуть лабораторный тестовый стенд, выполнить симуляцию целевого ransomware-воздействия и экспериментально верифицировать показатели RPO и RTO ;

Объектом исследования являются процессы резервного копирования, архивного хранения и аварийного восстановления данных корпоративной серверной инфраструктуры.

Предметом исследования выступают архитектурные методы, математические алгоритмы и программные средства обеспечения информационной безопасности резервных копий в условиях деструктивных воздействий программ-вымогателей.

Новизна работы заключается в проектировании комплексной проактивной системы защиты резервных копий, сочетающей архитектурную изоляцию хранилища в режиме строгой дозаписи (Append-Only) с превентивным программным анализом потока данных на стороне продуктивного хоста. В отличие от классических систем пассивного копирования, разработанное решение способно на уровне ядра ОС идентифицировать процесс несанкционированного криптографического преобразования файлов и блокировать сетевой доступ к репозиторию до момента коммита поврежденных данных.

Практическая значимость. Разработанная архитектура и программные компоненты представляют собой платформонезависимое решение на базе контейнеризации, которое может быть интегрировано в существующую ИТ-инфраструктуру предприятий без привлечения

дорогостоящих проприетарных средств защиты информации. Внедрение комплекса позволяет минимизировать риски безвозвратной потери данных, исключить финансовые затраты на выплату выкупов и сократить время простоя сервисов за счет автоматизированного контроля процедур восстановления. Результаты работы применимы для системных администраторов и специалистов по ИБ, проектирующих отказоустойчивые корпоративные сети.

Положения, выносимые на защиту:

- Архитектурное решение изолированного двухсерверного backup-контура, построенное на принципах Clean Architecture, использующее защищенные сетевые каналы передачи данных и отдельные домены аутентификации;
- Модуль превентивного анализа файловой активности на базе технологии eBPF, функционирующий на уровне ядра операционной системы Linux;
- Алгоритм оценки информационной энтропии Шеннона, обеспечивающий автоматическую блокировку backup-инфраструктуры при детектировании признаков шифрования данных ;
- Протокол автоматизированного тестирования процедур восстановления с экспериментальной фиксацией и верификацией целевых метрик RPO и RTO.

1 Исследование методов и средств защиты систем резервного копирования от вредоносного программного обеспечения

1.1 Анализ предметной области и существующих решений

Традиционный подход к обеспечению отказоустойчивости корпоративных информационных систем базируется на регулярном создании резервных копий (backup) и их хранении на выделенных сетевых ресурсах. Исторически архитектура систем резервного копирования (СРК) строилась на доверительной модели сети, где сервер баз данных или файловый сервер (продуктивный контур) имеет авторизованный сетевой доступ к хранилищу резервных копий по протоколам SMB, NFS или через специализированные агенты.

Анализ существующих enterprise-решений показывает, что большинство из них опирается на модель «Push» (инициатором резервного копирования выступает продуктивный сервер) и глубокую интеграцию с единым доменом аутентификации (например, Microsoft Active Directory). В условиях стандартной эксплуатации данный подход обеспечивает удобство централизованного администрирования. Однако эволюция вредоносного программного обеспечения, в частности программ-вымогателей (ransomware), продемонстрировала критическую уязвимость подобных плоских архитектур (Flat Networks).

В современной практике ransomware используется преимущественно в рамках целевых атак (Human-Operated Ransomware). При компрометации административных учетных данных продуктивной сети злоумышленник получает легитимный доступ не только к целевым базам данных, но и к панели управления СРК, а также к сетевым хранилищам (NAS). Это создает

единую точку отказа: вредоносное ПО шифрует или удаляет архивы, используя штатные протоколы доступа. Таким образом, само по себе наличие системы резервного копирования перестает быть гарантией возможности аварийного восстановления. Архитектура современной СРК должна строиться на парадигме Zero Trust (Нулевое доверие) и логической изоляции (Air-Gapping), где резервное хранилище является независимой подсистемой с собственной, строго ограниченной поверхностью атаки.

1.2 Анализ векторов ransomware-атак и техник ингибирования процессов аварийного восстановления

При проникновении в корпоративную сеть злоумышленники преследуют две основные цели: нарушить доступность продуктивных данных для остановки бизнес-процессов и подавить любые технические возможности их аварийного восстановления. В международной базе знаний тактик и техник целенаправленных кибератак MITRE ATT&CK данная стратегия формализована как техника «Inhibit System Recovery» (T1490).

Для проектирования защищенного программного комплекса необходимо формализовать модель нарушителя и определить ключевые векторы атак на backup-инфраструктуру. В рамках проектируемой системы выделяются три основных сценария деструктивного воздействия:

- 1. Шифрование на уровне продуктивного сервера:** Нарушитель получает несанкционированный доступ (вплоть до привилегий root/SYSTEM) к целевому серверу через эксплуатацию уязвимостей внешних сервисов или фишинг. Производится потоковое шифрование локальных дисков. Если система резервного копирования сработает по расписанию после начала атаки, в репозиторий будут отправлены

зашифрованные данные, что приведет к перезаписи легитимных инкрементальных срезов.

2. **Латеральное перемещение в backup-систему:** Используя полученные учетные данные или общие сетевые протоколы, нарушитель распространяет свое влияние на сервер резервного копирования, повышая привилегии до уровня администратора репозитория.
3. **Прямое уничтожение точек восстановления (T1490):** Вредоносное ПО выполняет команды очистки теневых копий томов (`vssadmin delete shadows` в Windows ОС или удаление LVM-снапшотов в Linux), удаляет каталоги с инкрементальными архивами и модифицирует политики удержания (Retention Policies).

Учитывая описанную модель угроз, разрабатываемый комплекс должен реализовывать концепцию неизменяемости данных (WORM-хранение) для защиты от удаления и превентивный контроль файловой активности для защиты от коммита зашифрованных массивов.

1.3 Обоснование выбора программно-технологического стека

Выбор технологического стека обусловлен жесткими требованиями к производительности системного мониторинга на продуктивном сервере, отказоустойчивости сетевого взаимодействия и необходимости ведения неизменяемого аудита инцидентов.

Уровень превентивного анализа и сбора (Хостовый агент) Для реализации программного агента-инспектора на стороне защищаемого сервера выбран язык **Python 3.11**. Для низкоуровневого перехвата файловых операций ввода-вывода (I/O) без модификации исходного кода ОС применяется технология ядра Linux — **eBPF (Extended Berkeley Packet Filter)**. Интеграция eBPF позволяет агенту собирать метрики интенсивности

файловых операций (IOPS) и анализировать энтропию изменяемых данных с минимальными накладными расходами (overhead), не создавая задержек для работы бизнес-приложений.

Уровень хранения и оркестрации резервных копий (Storage) В качестве ядра резервного копирования на изолированном сервере применяется система **BorgBackup**, функционирующая в режиме *Append-Only* (WORM). Данный режим аппаратно-программно блокирует возможность удаления существующих архивов со стороны клиента. Для фиксации событий ИБ, хранения метрик энтропии во времени и аудита доступа применяется реляционная СУБД **PostgreSQL** со специализированным расширением **TimescaleDB**. Механизм гипертаблиц (Hypertables) оптимизирован для записи высокочастотных временных рядов (Time-series data), генерируемых модулем eBPF.

Клиентский уровень (Frontend и API) Служба управления (API-шлюз) реализуется с использованием асинхронного веб-фреймворка **FastAPI**. Панель мониторинга и администрирования разрабатывается на базе современного веб-фреймворка **Nuxt 4 (Vue 3.5)** с применением строгой типизации **TypeScript**. Это обеспечивает создание реактивного пользовательского интерфейса для визуализации текущих показателей RPO (Recovery Point Objective) и метрик энтропии.

Инфраструктура и сетевая изоляция Для обеспечения сетевой парадигмы Zero Trust между продуктивным сервером и backup-репозиторием разворачивается зашифрованный VPN-туннель на базе протокола **WireGuard**. Развертывание управляющих микросервисов осуществляется с использованием платформы контейнеризации **Docker**, что гарантирует воспроизводимость среды исполнения.

1.4 Постановка задачи на разработку системы

Основываясь на проведенном анализе предметной области и обоснованном выборе технологического стека, формируется техническое задание на разработку программно-аппаратного комплекса защищенного резервного копирования. Система должна представлять собой распределенную архитектуру, обеспечивающую полный цикл безопасного контроля, передачи и неизменяемого хранения резервных копий.

Функциональные требования к системе:

1. Разработка модуля превентивного анализа для непрерывного перехвата вызовов файловой системы (через eBPF) на продуктивном сервере.
2. Реализация математического алгоритма вычисления энтропии Шеннона для записываемых блоков данных в режиме реального времени с целью превентивного обнаружения работы ransomware-модулей.
3. Организация алгоритма автоматической блокировки сетевого туннеля и остановки задач резервного копирования при превышении установленного порога энтропии файловой системы.
4. Настройка изолированного хранилища данных в строгом режиме Append-Only, разрешающем исключительно дозапись новых инкрементальных срезов без прав на удаление со стороны продуктивного узла.
5. Создание веб-панели администратора для настройки расписания, визуализации графиков изменения информационной энтропии и мониторинга отклонений от заданных параметров восстановления (RPO).

Нефункциональные требования к системе:

1. **Изоляция (Air-Gapping):** логическое разделение доменов аутентификации. Компрометация учетных записей уровня root на продуктивном сервере не должна предоставлять нарушителю технических привилегий для управления backup-сервером.
2. **Производительность:** процесс вычисления энтропии и eBPF-мониторинга файлов не должен снижать пропускную способность дисковой подсистемы продуктивного сервера более чем на 5-7%.
3. **Архитектурная чистота:** реализация бэкенд-составляющей должна базироваться на принципах Clean Architecture, обеспечивая независимость логики аудита от конкретных реализаций СУБД.
4. **Воспроизводимость:** платформа управления и мониторинга должна поставляться в виде набора Docker-контейнеров для возможности развертывания на стандартизированных Linux-серверах.